

Legacy Application Knowledge Extractor — come funziona

Due parti. La **prima** si legge senza sapere niente di programmazione: spiega a cosa serve l'applicazione e cosa fa, dall'inizio alla fine. La **seconda** è per chi ci deve mettere le mani: spiega i meccanismi, file per file.

PARTE 1 · In parole semplici

Il problema che risolve

In quasi tutte le aziende grandi c'è un programma vecchio che continua a funzionare e che nessuno sa più spiegare. È stato scritto vent'anni fa, chi l'ha scritto è andato in pensione, la documentazione non esiste — o esiste ma descrive una versione che non c'è più. Nel frattempo quel programma calcola gli sconti, emette le fatture, decide quali pratiche si bloccano.

Quando arriva il momento di rifarlo, di spostarlo sul cloud o semplicemente di capire perché fa una certa cosa, ci si trova davanti a un muro: **l'unica documentazione che dice la verità è il codice**, e il codice lo sanno leggere in pochi. Il lavoro tradizionale è mandare uno o due analisti a leggerlo per settimane, prendendo appunti.

Questa applicazione fa quel primo lavoro di lettura, in qualche minuto, e lo consegna in un formato che un esperto può correggere e firmare.

Cosa fa, in una frase

Le si dà del codice sorgente. Lei lo legge, ne ricava un documento che spiega cosa fa quel programma, quali regole di business contiene, con che altri sistemi parla, quali rischi si porta dietro — e lo consegna in Word, PDF o dati grezzi.

Come lo fa: due lettori diversi

Il punto interessante è che il codice viene letto **due volte, da due lettori con caratteri opposti**.

Il primo lettore è meccanico. Non capisce niente di quello che legge, ma non sbaglia mai. Sa riconoscere per certo che in quel file c'è una procedura che si chiama `CALC_SCONTO`, che tocca la tabella `ORDINI`, che c'è una password scritta a chiare lettere dentro il codice (cosa che non si dovrebbe mai fare) e che una certa istruzione può cancellare dei dati. Sono **fatti**: o ci sono o non ci sono, e non c'è opinione che tenga.

Il secondo lettore è un modello di intelligenza artificiale. Capisce il senso, ma può sbagliare. Sa dire che quelle trenta righe, messe insieme, significano «se l'ordine supera i cento euro si applica lo sconto del dieci per cento, tranne per i clienti esteri». È quello che serve davvero: il primo lettore ti dà l'elenco dei pezzi, il secondo ti dice a cosa servono.

L'applicazione fa parlare i due lettori tra loro. **Al modello vengono passati i fatti del lettore meccanico insieme al codice**, con l'istruzione esplicita di non contraddirli. Poi i due risultati vengono uniti in un'unica tabella, dove per ogni riga è scritto **chi l'ha trovata e quanto è sicura**.

Questo è il cuore di tutto: un'informazione che viene dal lettore meccanico ha un valore diverso da una che viene dal modello, e nel documento finale la differenza resta visibile. Non si mescolano i fatti con le interpretazioni.

Come si legge quello che trova

Ogni riga porta scritto da dove viene e quanto è solida, e lo dice con una forma oltre che con un colore: un quadrato pieno è un fatto del lettore meccanico, che su quello non può sbagliare; un quadrato vuoto è la lettura del modello, con accanto tre pallini che dicono quanto ci crede. La gravità dei rischi è l'unica cosa calda della pagina, così l'occhio ci va per primo. Niente è affidato al solo colore: chi non distingue il rosso dal verde, e chi stampa in bianco e nero, legge le stesse identiche informazioni.

Il terzo lettore: la persona

Il documento non è finito quando l'applicazione ha finito. Ogni cosa trovata finisce in una tabella con **una casella da spuntare**: è lì che un esperto di quel dominio — chi conosce il business, non chi conosce il codice — passa riga per riga e conferma, corregge o cancella.

L'applicazione lo aiuta scrivendo anche una lista di **domande a cui il codice non sa rispondere**. Per esempio: nel codice c'è scritto «trenta giorni», ma *perché* trenta? È un termine di legge, un accordo con un fornitore, o un numero che qualcuno ha scritto nel 2003 e nessuno ha più toccato? Quella risposta non sta nel codice, sta nella testa di qualcuno. L'applicazione sa di non saperlo, e lo chiede invece di inventare.

Il giro completo

1. **Si caricano i file.** Codice Oracle, COBOL, Java, Python, e altri. Oppure si incolla direttamente un pezzo di codice.
2. **L'applicazione legge meccanicamente.** In pochi secondi, senza costi.
3. **Manda tutto al modello.** Se il codice è tanto, lo divide in lotti e ne manda uno alla volta, senza mai spezzare un file a metà.
4. **Rimette insieme e ripulisce.** Toglie i doppioni, numera le righe, raddrizza quello che il modello ha scritto male.
5. **Mostra tutto in schede:** sintesi, regole di business, architettura, flussi di dati, rischi, diagrammi, domande per l'esperto.
6. **L'esperto valida.** Spunta, corregge, cancella.
7. **Si esporta** in Word, PDF o dati grezzi.

Quanto ci mette

Dipende quasi tutto da una manopola: **quanto si lascia pensare il modello** prima che risponda. Lo stesso modello, con il ragionamento al massimo, impiega minuti dove al minimo impiega secondi. La manopola è nella barra laterale (*Reasoning effort*), e l'applicazione la adatta da sola: alcuni modelli non accettano i livelli più bassi, e in quel caso lei sale di un gradino invece di fermarsi con un errore.

Detto questo, un'analisi vera dura minuti, non secondi: si stanno leggendo decine di migliaia di righe. La barra di avanzamento mostra i secondi che passano, e alla fine è scritto quanto è durata.

I diagrammi

Ci sono quattro disegni: come scorre un processo, con che sistemi esterni parla l'applicazione, dove vanno i dati, e chi chiama chi dentro il codice.

Non li disegna il modello — o meglio, se lui li produce vengono tenuti, ma **normalmente vengono costruiti dalle tabelle stesse**. È una scelta precisa: se il disegno nasce dalle tabelle, non può raccontare una cosa diversa da quello che c'è scritto nelle tabelle. E soprattutto, quando l'esperto corregge una riga, **il disegno si può rifare** e si aggiorna. Prima capitava che qualcuno cancellasse un collegamento sbagliato e il disegno continuasse a mostrarlo: il documento firmato conteneva due verità diverse.

I diagrammi vengono anche disegnati **sul computer di chi usa l'applicazione**, non mandati a un servizio su internet. Su codice di un cliente è una differenza che conta.

Cosa questa applicazione NON fa

Vale la pena essere netti, perché le aspettative sbagliate su questi strumenti sono la cosa che li fa fallire.

- **Non riscrive il programma** e non lo traduce in un altro linguaggio.
- **Non garantisce di aver trovato tutto.** Gli indicatori dicono quanto è solido quello che ha trovato — quanti file ha citato, quante righe hanno un riscontro nel codice — non quanta parte dell'applicazione ha capito. Nessuno strumento automatico può dire quest'ultima cosa.
- **Non sostituisce l'esperto.** Produce una bozza ragionata da correggere. Un documento uscito da qui e non validato da nessuno non vale più della bozza che è.

- **Non è un giudice.** Quando dice che una cosa è «rischiosa» sta segnalando un sospetto, con un livello di gravità; sta a chi legge decidere.

Perché è costruita così

Tre idee attraversano tutto il progetto, e conviene conoscerle perché spiegano quasi ogni scelta:

Un dato inventato è peggio di un dato mancante. Un buco lo si vede e lo si riempie. Una riga plausibile ma falsa entra nel documento, viene firmata, e qualcuno ci costruisce sopra un progetto di migrazione.

Chi legge deve sapere da dove viene ogni cosa. Fatto certo o interpretazione, macchina o modello, quanto sicuro: sempre scritto.

Un messaggio deve promettere solo quello che il codice farà davvero. Se qualcosa non funziona perché la chiave d'accesso è sbagliata, l'applicazione non dice «riprova più tardi» — perché riprovando non cambierà niente, e chi legge perderebbe la giornata. Dice che la chiave è sbagliata.

PARTE 2 · Per gli addetti ai lavori

Architettura

Applicazione Streamlit, otto moduli Python più uno script di servizio, nessun database, nessuno stato sul server oltre alla sessione.

File	Responsabilità
app.py	Interfaccia, analisi statica, orchestrazione, stato di sessione
model_chain.py	Scoperta, prova e scalata dei modelli sui tre provider
contract.py	Il contratto JSON: prompt, schema, riparazione, normalizzazione
diagrams.py	I quattro diagrammi ricavati dai dati strutturati
mermaid_render.py	Mermaid → PNG, in locale (mmdc) o come ricaduta remota
exporter.py	PDF (ReportLab) e Word (python-docx)
test_catena.py	72 casi, senza rete, senza chiavi, senza costi
guida_pdf.py	Rigenera questo documento in PDF (servizio, non serve all'app)
.streamlit/config.toml	Tema di Streamlit, con gli stessi colori di ui.py

Le dipendenze fra moduli vanno in una direzione sola: app → tutti; exporter → mermaid_render; diagrams → contract. Nessun ciclo, e model_chain non sa niente né di Streamlit né del dominio: si può usare da riga di comando o riportare in un altro progetto così com'è.



Fase 1 — Ingestione

`build_source_collection` decodifica ogni file provando UTF-8, UTF-8-BOM, CP1252, Latin-1 in quest'ordine (i sorgenti legacy sono quasi sempre CP1252 o EBCDIC convertito male), calcola uno SHA-256 troncato per file e riconosce il linguaggio dall'estensione. Tetti: 2 MB per file, 1,5 M caratteri in totale.

`split_into_batches` divide in lotti da ~120.000 caratteri ordinando per dimensione decrescente e **senza mai spezzare un file**: un file tagliato a metà produce regole di business monche, che è peggio di un file in meno.

Fase 2 — Analisi statica

Tutto in `app.py`, sezioni 5 e 6. Produce i **fatti**.

Parsing SQL (`parse_sql_expressions`): `sqlglot` con `error_level="ignore"`, provando in sequenza i dialetti `None`, `oracle`, `mysql`, `postgres`, `tsql` e tenendo il primo che restituisce un albero non vuoto. Dall'AST si estraggono tabelle (`exp.Table`), colonne (`exp.Column`), tipo di operazione e JOIN con la condizione.

Riconoscimento a espressioni regolari per quello che `sqlglot` non copre:

- componenti: `PROCEDURE`, `FUNCTION`, `PACKAGE`, metodi Java, `def` Python, `function` JavaScript, paragrafi COBOL;
- dipendenze dichiarate: `import`, `require`, `#include`, `COPY`, `/COPY`;
- dipendenze probabili: `CALL`, `EXEC`, `PERFORM`, e il pattern generico «identificatore seguito da parentesi», con esclusione dei costruttori (`new X()`) e di ~120 nomi di libreria;
- interfacce: URL, riferimenti a file, REST, SOAP, code di messaggi, SMTP, FTP;
- rischi: credenziali scritte nel codice (`CRITICAL`), SQL dinamico (`HIGH`), gestori di eccezione generici o vuoti, `COMMIT` espliciti, `SELECT *`;
- operazioni sui dati: `READ` / `CREATE` / `UPDATE` / `DELETE` / `MERGE` / `DDL`.

Tetto di **300 righe per tipo di ritrovamento per file**. Senza, il pattern generico su un Java da 5.000 righe produce migliaia di dipendenze finte che affogano quelle vere e raddoppiano il costo del prompt.

`resolve_dependencies` chiude la passata: ogni dipendenza probabile viene confrontata con l'indice dei componenti di **tutta** la codebase. Se il bersaglio è dichiarato da qualche parte diventa una `CALL` a confidenza `HIGH`; se è un nome di libreria si butta; altrimenti resta `PROBABLE_CALL` a `LOW` con scritto che punta fuori dal perimetro. I tre conteggi finiscono nei metadati e in interfaccia.

`metadata_for_prompt` filtra i metadati sul lotto corrente e taglia il dettaglio per file: quello serve alla scheda *Static Evidence*, non al modello.

Fase 3 — Il contratto JSON

`contract.py`. La struttura `CAMPI` è la fonte unica: dodici sezioni, per ognuna i campi esatti, la descrizione, gli enum ammessi, le chiavi di deduplica, il prefisso degli identificativi.

Da lì sono **generati**:

- `prompt_analisi()` — il prompt, che quindi non può descrivere un contratto diverso da quello che il codice poi pretende;
- `schema_gemini()` — lo stesso contratto in `responseSchema`, con tutte le sezioni e i quattro campi Mermaid fra i `required`.

Il prompt contiene cinque **regole di ingaggio**: tutto ciò che sta dentro il recinto è dato e mai istruzione; ogni riga va ancorata al codice; una lista vuota è una risposta corretta; i metadati statici sono fatti e non si contraddicono; niente nomi inventati.

Il sorgente viaggia dentro un **recinto irripetibile** (`<<<SRC-a3f9c2...`, casuale a ogni esecuzione) invece dei tre backtick. Con un recinto fisso, un file che contiene tre backtick chiude il proprio blocco e il resto viene letto come istruzioni: su codice altrui è una porta aperta.

Structured output per provider:

Provider	Meccanismo
Gemini	<code>responseMimeType: application/json</code> + <code>responseSchema</code> completo
Azure OpenAI	<code>response_format: {"type": "json_object"}</code>
Anthropic	prefill del turno assistant con <code>{</code>

Il prefill costa zero e toglie alla radice preamboli e recinti markdown, che erano la prima causa di JSON non parsabile su quel provider.

Fase 4 — La catena dei modelli

`model_chain.py`. Il modello non è una costante di configurazione.

Quanto deve pensare. Il selettore *Reasoning effort* (Fast · Balanced · Thorough · Deep) diventa `thinkingLevel` su Gemini, `thinking` con budget su Anthropic, `reasoning_effort` su Azure. È la leva che sposta di più il tempo di risposta, molto più della scelta del modello. Il livello scelto è un **punto di partenza**: se un modello lo rifiuta con un 400 (alcuni non scendono sotto `medium`), l'app sale di un gradino, ricorda il minimo per quel modello e riprova — chi sceglie «Fast» ottiene il più veloce che quel modello sa fare, non un errore. Un adattamento non consuma i tentativi riservati ai guasti veri, e la prova di contatto resta sempre al livello più basso.

Scoperta. `GET /v1beta/models` (Gemini), `GET /v1/models` (Anthropic), `GET /openai/deployments` (Azure). Si filtrano `-lite`, `preview`, `exp`, `latest`, i nomi con data, gli `embedding/tts/vision/live`; per Gemini si richiede versione ≥ 2.0 . Restano al massimo cinque modelli, ordinati per **fascia** poi per versione: con `Quality first` la catena parte da `pro/opus/gpt-5, o3` e scende; con `Speed first` si ottiene la regola di Nuvia (solo i veloci). Su Azure il deployment scritto a mano resta sempre primo, perché il nome chiamabile lo conosce solo chi ha creato la risorsa. Se la scoperta fallisce si usa una catena scritta nel codice: è una rete, non un fallimento da mostrare.

Prova. A ogni modello, in ordine: «Rispondi con una sola parola: OK», tetto **5 s per modello** e **10 s complessivi**. Il primo che risponde vince. Un secondo tentativo sullo stesso modello solo su guasti transitori e solo se restano almeno altri 5 s: altrimenti la seconda chance è il modello dopo, che vale di più. Un 200 con testo vuoto conta come vivo (i modelli che ragionano possono consumare il tetto di token del test prima di scrivere).

Chiamata vera. Parte dal modello che ha risposto e scende **solo in giù**, mai risale: tre tentativi per modello con attesa crescente.

Tassonomia dei guasti, unica per i tre provider: `quota`, `modello`, `badkey`, `busy`, `timeout`, `rete`, `vuota`, `troncata`, `blocked`, `contesto`, `parametro`. Ogni provider traduce il proprio dialetto HTTP in questi nomi. Tre insiemi decidono il comportamento: `RIPROVA` (stesso modello), `CAMBIA` (modello successivo), `NON_SCENDERE` (inutile proseguire).

Il 400 che non è una chiave sbagliata. Prima di dare la colpa alla chiave si legge il corpo dell'errore: se parla di schema, `temperature`, `max_completion_tokens` o `thinking`, si adatta la richiesta, si **ricorda l'adattamento per quel modello** e si riprova. La volta dopo si parte già giusti. È lo stesso meccanismo del `thinkingLevel` di Nuvia.

Guardia a orologio. Ogni richiesta gira in un thread contro una scadenza vera, perché il `timeout` di `requests` è per singola lettura del socket: un server che manda un byte ogni tre secondi non lo fa scattare mai e il tetto dei cinque secondi smette di esistere.

Memoria. Modello buono 10 minuti, elenco scoperto 6 ore, adattamenti per sempre. Su file o in RAM. Della chiave si salva solo un'impronta SHA-256 troncata come identità della cache: due chiavi non si scambiano i dati e la chiave non finisce mai su disco.

I messaggi. «Riprova più tardi» solo se riprovare può cambiare qualcosa. Chiave sbagliata, quota esaurita, contesto pieno hanno il loro messaggio, in italiano e in inglese.

Il trasporto è `requests` diretto, non i tre SDK: gli SDK ritentano per conto loro *sopra* la nostra scalata (il client OpenAI ritenta i 429 di default, mangiandosi il tempo del nostro tetto) e nascondono lo status HTTP che la tassonomia usa per decidere.

Fase 5 — Rientro e normalizzazione

`estrai_json` toglie eventuali recinti, tenta `json.loads`, poi tenta il sottoinsieme fra la prima `{` e l'ultima `}`, poi chiama `ripara_troncato`.

`ripara_troncato` scorre il testo tracciando stringhe, sequenze di fuga e pila delle parentesi, torna all'ultimo confine sicuro e richiude quello che era aperto. **Il tetto di token è il modo più comune di perdere un'analisi da tre minuti:** prima l'ultima riga a metà faceva buttare anche le duecento righe perfette che venivano prima.

`normalizza` fa il resto: campi mancanti riempiti, nomi di campo simili recuperati, enum raddrizzati con una tabella di sinonimi («High», «critico», «Sev2»), liste convertite in testo (`A; B`), celle tagliate a 1.500 caratteri, righe vuote scartate, dopponi tolti sulle chiavi dichiarate, identificativi assegnati **dal codice** (il modello riparte da 1 a ogni lotto), Mermaid ripulito. Tutto quello che ha dovuto aggiustare finisce in `contract_warnings`, visibile in interfaccia: chi valida deve sapere quanto fidarsi.

La pulizia Mermaid merita una riga: le etichette vengono messe fra virgolette e ripulite da `( ) [ ] { } " ; |` con uno scanner scritto a mano, non con una regex, perché le forme si annidano (`A[Ordine (nuovo)]`) e una regex prende la parentesi interna lasciando fuori quella che conta. Lo stesso scanner sa distinguere il testo visibile dagli identificatori, e nei secondi rinomina le proprietà del prototipo JavaScript (`toString`, `valueOf`, `constructor`...) che altrimenti fanno morire il renderer. `end` e `subgraph` restano intatti: lì la parola ha un significato.

Consolidamento. Con più di un lotto parte una chiamata finale che riceve **solo l'inventario**, senza codice: produce una sintesi unica dell'applicazione e cerca i collegamenti fra lotti diversi. Ogni nome che torna viene verificato contro l'inventario — in quella chiamata il modello non ha il codice davanti, quindi un nome inventato non lo smentirebbe nessuno. Se fallisce, si tengono le sintesi per lotto e lo si dichiara.

`unisci` somma i lotti sulle stesse chiavi di deduplica, concatena i testi, per i diagrammi tiene il più completo (due `flowchart TD` incollati non si disegnano) e rinumera.

`merge_static_and_ai_results` fa passare **anche le righe del parser** dal contratto prima di unirle: è l'unico modo perché le tabelle abbiano le stesse colonne.

Fase 6 — I diagrammi

`diagrams.py` costruisce i quattro disegni dai dati strutturati: `call graph` da `dependencies`, `application map` da `application_mapping` (o `interfaces`), `data flow` da `data_flows` (o `data_objects`), `process flow` da `business_processes`. Si costruiscono **dopo** l'unione con l'analisi statica, così il call graph contiene anche le dipendenze trovate dal parser.

`arricchisci` sceglie: se il modello ha prodotto qualcosa di sostanzioso (≥ 3 righe) resta il suo, altrimenti si mostra quello costruito. Entrambe le versioni restano nel risultato e in interfaccia c'è l'interruttore, più un bottone che rifà i disegni dalle tabelle correnti — cioè dopo le correzioni dello SME. La provenienza si scrive accanto al disegno, **non** fra gli avvisi di contratto: costruire il diagramma dai dati è il funzionamento previsto, e nel pannello degli avvisi sembrava un guasto.

Garanzie per costruzione: id unici e sempre preceduti da `n_` — un id nudo può coincidere con una proprietà che ogni oggetto JavaScript eredita (`toLocaleString`, `constructor`), e Mermaid, che tiene i nodi in un oggetto normale, crede che il nodo esista già e muore con «Cannot set properties of undefined (setting 'order')»; etichette senza i caratteri che rompono

mermaid; tetto di 40 archi con dichiarazione di quanti restano fuori; quando si taglia, escono per prime le `PROBABLE_CALL` e le confidenze basse.

Fase 7 — Rendering ed esportazione

`mermaid_render.rendi` prova nell'ordine: `mmdc` locale (`@mermaid-js/mermaid-cli`, cioè `mermaid.js` dentro un Chromium headless), poi `npm` se esplicitamente abilitato, poi `mermaid.ink` come ricaduta. `MERMAID_LOCAL_ONLY=1` vieta del tutto l'uscita. Gestisce `--no-sandbox` per i container con un file di configurazione Puppeteer temporaneo, rispetta `PUPPETEER_EXECUTABLE_PATH`, e mette in cache sull'impronta del codice (PDF e Word chiedono gli stessi quattro diagrammi).

`exporter.py` costruisce PDF in A4 orizzontale e Word con tabelle generate automaticamente dalle chiavi dei dizionari — motivo per cui il contratto uniforme migliora anche gli export. Le immagini vengono inserite **rispettando le proporzioni lette dall'intestazione del PNG** (24 byte, nessuna dipendenza in più) e adattate al riquadro disponibile.

Stato, cache e costi

Streamlit riesegue lo script intero a ogni interazione. Di conseguenza:

- il risultato vive in `st.session_state` e le modifiche delle tabelle ci rientrano a ogni giro;
- `analysis_signature` (impronta dei file + provider + versione del contratto) evita di rilanciare un'analisi a pagamento identica alla precedente;
- PDF e Word si generano **su richiesta** e sono in `st.cache_data`: prima ogni spunta su una casella rigenerava entrambi, scaricando otto immagini.

Collaudo

`python test_catena.py` — 72 casi, nessuna rete, nessuna chiave, nessun costo. Il provider è finto: si dichiara quali modelli rispondono e come, e si osserva il comportamento. Copre scoperta e ordinamento, scalata, riprova selettiva, memoria, messaggi nelle due lingue, tetti temporali, adattamento dei parametri, riparazione del JSON, enum, deduplica, Mermaid, lotti, geometria delle immagini e costruzione dei diagrammi.

Limiti noti e dove mettere le mani

- **Le chiavi stanno nella barra laterale.** Va bene per un prototipo; per più utenti servono variabili d'ambiente o un gestore di segreti.
- **Nessun numero dice quanta parte dell'applicazione è stata catturata**, e nessuno può dirlo: servirebbe conoscere in anticipo la risposta. Gli indicatori misurano l'ancoraggio (file citati, righe con evidenza, confidenza, chiamate non risolte); l'elenco dei file che nessuna riga menziona è il segnale più utile che l'applicazione sa dare su se stessa.
- **Le chiamate fuori perimetro restano un sospetto.** Ora sono marcate `LOW` e contate, ma distinguere una chiamata vera da un cast o da un costruttore in ogni linguaggio richiede un parser per linguaggio, non un'espressione regolare.
- **Il process flow del modello resta migliore del nostro** quando lui lo produce: sa mettere i passi in ordine di esecuzione, cosa che dalle tabelle non si ricava. Non è un difetto: è il motivo per cui il suo disegno viene tenuto quando c'è.
- **Il consolidamento vede l'inventario, non il codice.** Può collegare due nomi già trovati, non scoprire quello che nessun lotto ha visto.